Progetto W20D2
Security Operation

Indice:

1. Introduzione
2. Azioni preventive
3. Impatti sul business
4. Response
5. Soluzione completa

1. Introduzione

In questo progetto viene analizzata la sicurezza di un'architettura Web rappresentata nella figura di riferimento (Figura 1), valutandone sia le vulnerabilità sia le possibili contromisure. L'esercizio è articolato in più scenari operativi che simulano reali minacce informatiche ai danni di una piattaforma di e-commerce.

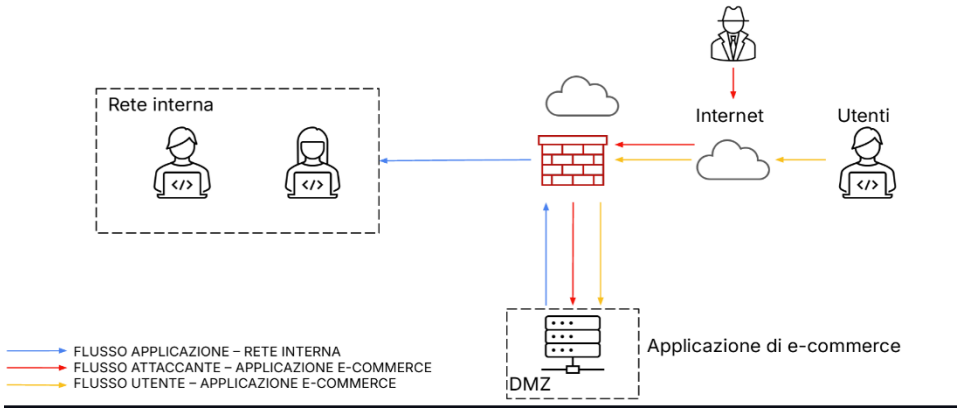

Figura 1

Il primo obiettivo è identificare e descrivere le **azioni preventive** contro **SQL Injection** e Cross- Site Scripting (XSS), aggiornando la figura per mostrare le protezioni. Si esamina poi l'impatto economico di un attacco **DDoS** di dieci minuti, calcolando la perdita e suggerendo soluzioni preventive. La terza parte riguarda un caso di **malware sull'applicazione Web**, con priorità al contenimento della propagazione nella rete interna e aggiornamento della figura architetturale. Infine, occorre proporre una **soluzione integrata** e, facoltativamente, una modifica strutturale più incisiva per rafforzare la sicurezza.

2. Azioni preventive

Quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo SQLi oppure XSS da parte di un utente malintenzionato? Modificate la figura in modo da evidenziare le implementazioni

Al fine di tutelare l'integrità dell'infrastruttura e la sicurezza dei dati aziendali, è essenziale adottare una serie di misure preventive, strutturate su diversi livelli. L'obiettivo principale consiste nel ridurre la superficie di attacco e ostacolare ogni tentativo di accesso non autorizzato o compromissione.

Livello applicativo

- Utilizzo di prepared statements;
- Validazione dell'input;
- Encoding dell'output;
- Configurazione di Content Security Policy (CSP);
- Impiego di cookie sicuri;

Livello infrastrutturale

- Applicazione di Web Application Firewall (WAF);
- Segmentazione tramite DMZ;
- Implementazione di firewall;

Livello organizzativo

- Formazione del personale;
- Definizione di procedure per lo sviluppo sicuro;

SQL Injection: definizione e rischi

Structured Query Language è il linguaggio standard utilizzato per la gestione dei dati nei database relazionali. Attraverso SQL è possibile effettuare operazioni fondamentali quali interrogazioni, aggiornamenti, inserimenti, eliminazioni e la gestione stessa delle strutture di database.

Un attacco di tipo SQL Injection (SQLi) si verifica quando un malintenzionato sfrutta le vulnerabilità presenti nelle applicazioni web per inviare comandi SQL malevoli al database sottostante. L'obiettivo principale di questi attacchi è quello di estrarre, modificare o eliminare dati sensibili, ma può anche includere l'esecuzione di comandi a livello di sistema operativo o il causare un Denial-of-Service, interrompendo la disponibilità del servizio.

Conseguenze di una SQL Injection

Mediante una SQL injection, un utente non autorizzato può manipolare i comandi che l'applicazione web invia al database, producendo danni significativi. Tra le principali conseguenze vi sono l'accesso illecito a credenziali, dati sensibili e informazioni su transazioni degli utenti. Considerata la varietà e la gravità degli attacchi possibili, è fondamentale adottare un insieme di tecniche di difesa integrate per proteggersi efficacemente da questa tipologia di minaccia.

Cross-Site Scripting (XSS) definizione

Un attacco ***Cross-Site Scripting (XSS***) è una vulnerabilità web che consente agli aggressori di iniettare script dannosi, solitamente JavaScript, nelle pagine visualizzate dagli utenti. Questi script possono accedere a cookie, dati sensibili e funzioni dell'account, mascherandosi da contenuti legittimi del sito. Secondo OWASP, XSS è una forma di code injection causata dall'assenza di validazione degli input e output. Gli attacchi XSS possono rubare i cookie di sessione e permettere agli hacker di impersonare l'utente su un server.

Livello applicativo (sicurezza del software)

• *Utilizzo di Prepared Statements*

L’impiego di prepared statements rappresenta una delle principali misure preventive contro gli attacchi SQL Injection. Queste query parametriche separano efficacemente i dati dalla logica SQL, impedendo che input potenzialmente dannoso venga eseguito come comando.

• *Validazione dell'input*

La verifica dei dati in ingresso è fondamentale prima dell’utilizzo in applicazione. È necessario assicurarsi che i dati rispettino formato, lunghezza e tipologia previsti, scartando valori inattesi per prevenire injection o comportamenti anomali. Ad esempio, si validano email tramite espressioni regolari, date e intervalli numerici.

• *Encoding dell'output*

Prima della visualizzazione, i dati devono essere opportunamente codificati, soprattutto se destinati al browser. Questa pratica protegge da attacchi XSS convertendo caratteri speciali (<, >, ") in entità HTML e garantendo che l’input utente non sia interpretato come codice.

• *Configurazione di Content Security Policy (CSP)*

La definizione di una CSP costituisce una difesa robusta contro l’XSS, specificando le fonti consentite per script, immagini e stili. La CSP fornisce un meccanismo che indica al browser quali fonti sono attendibili, e accettate dal browser, tenendosi così alla larga dall’utilizzo di contenuti pericolosi, quali ad esempio script dannosi o immagini contenenti malware.

• *Impiego di cookie sicuri*

È necessario configurare gli attributi dei cookie per tutelare le sessioni e l'autenticazione:

- HttpOnly
- Secure
- SameSite

Tali accorgimenti riducono i rischi di furto di cookie e attacchi CSRF.

Livello infrastrutturale (sicurezza rete)

• *Web Application Firewall (WAF)*

E' un sistema di sicurezza che **protegge le applicazioni Web** filtrando, monitorando e bloccando il traffico HTTP/HTTPS tra Internet e l'applicazione stessa.

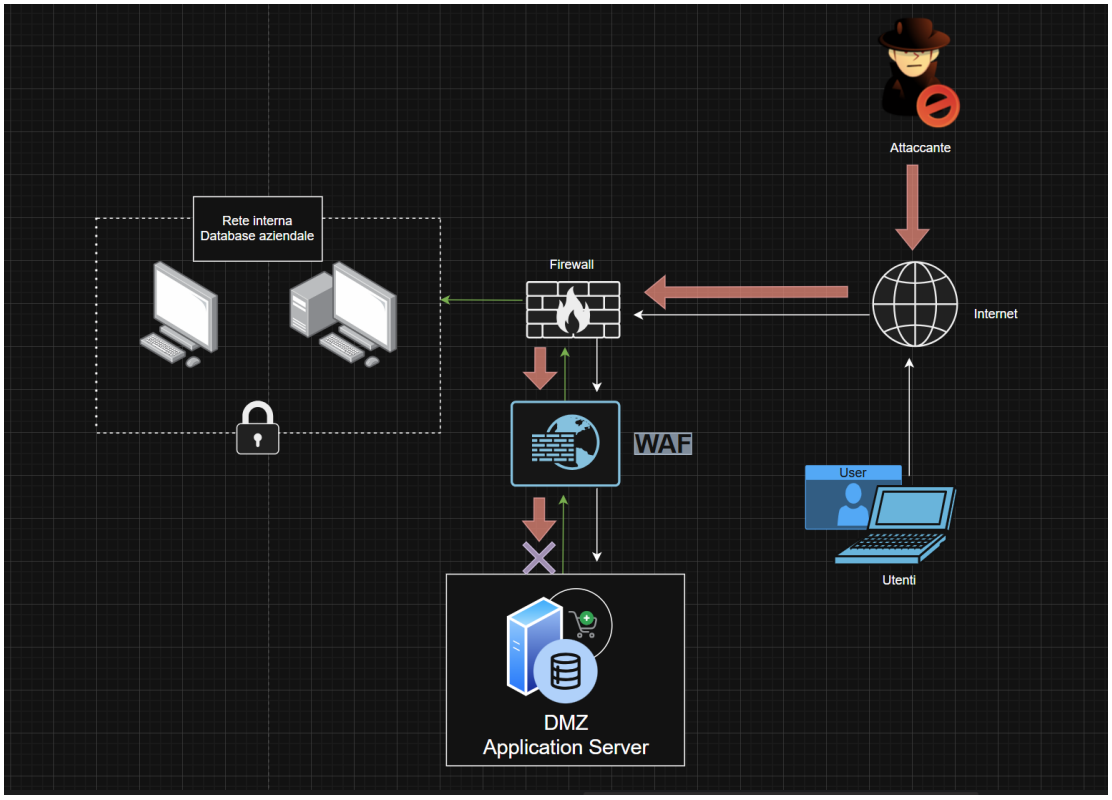

Figura 2

Funziona come **uno scudo** posizionato davanti all' applicazione per bloccare attacchi prima che raggiungano il codice.

• *Segmentazione tramite DMZ*

La realizzazione di una DMZ, ovvero una zona di rete separata e controllata, permette di isolare i servizi esposti a Internet dagli ambienti interni, aumentando la sicurezza della rete aziendale. Anche in caso di compromissione di un server nella DMZ, l'accesso ai sistemi interni risulta limitato.

• *Implementazione di firewall*

I firewall sono strumenti essenziali per filtrare e monitorare il traffico tra diverse aree della rete. Applicano regole di allow/deny per prevenire accessi non autorizzati e segmentare i diversi livelli applicativi (front-end, back-end, database), rappresentando la prima barriera contro le intrusioni esterne.

Livello organizzativo (persone e processi)

• *Formazione del personale*

La componente umana è centrale nella sicurezza informatica; è pertanto fondamentale formare gli utenti sui principali rischi, come phishing e social engineering, sulle buone pratiche di gestione password e accessi, sul riconoscimento dei comportamenti sospetti e sulle metodologie di secure coding per sviluppatori. Un'adeguata formazione riduce sensibilmente il rischio di incidenti.

• *Definizione di procedure per lo sviluppo sicuro*

Occorre adottare processi strutturati e linee guida chiare che integrino la sicurezza nel ciclo di vita dello sviluppo software. Tali processi includono:

- Linee guida di secure coding (ad es. OWASP, MISRA);
- Code review orientate alla sicurezza;
- Analisi statica e dinamica;
- Penetration Test periodici;
- Gestione delle dipendenze e patching;
- Politiche di gestione delle vulnerabilità;

Le norme di sicurezza seguono le best practice OWASP, in particolare il documento Top 10, identificando vulnerabilità e misure preventive già in fase di sviluppo. OWASP offre strumenti come ZAP, uno scanner gratuito per verificare la sicurezza delle applicazioni prima della pubblicazione.

3. Impatti sul business

L'applicazione Web subisce un attacco di tipo DDoS dall'esterno che rende l'applicazione non raggiungibile per 10 minuti. Calcolare l'impatto sul business dovuto alla non raggiungibilità *del servizio, considerando che in media ogni minuto gli utenti spendono 1.500* **€** *sulla piattaforma di e-commerce. Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica*

Attacco DDoS

Un **attacco DDoS** costituisce una minaccia informatica in cui un soggetto malintenzionato mira a rendere indisponibile un servizio, sito web o infrastruttura, generando un sovraccarico tramite volumi elevati di traffico provenienti da numerose fonti contemporanee.

Il Sistema di Informazione per la Sicurezza della Repubblica (SISR - Governo Italiano) definisce il DDoS come "*un attacco originato da molteplici fonti simultaneamente che conduce alla saturazione delle risorse e all*'indisponibilità del servizio".

Per ridurre al minimo l'impatto degli attacchi DDoS e garantire la continuità operativa, risulta fondamentale combinare misure tecniche con appropriati piani di gestione, quali:

● Il BCP (Business Continuity Plan) definisce le procedure volte a ridurre al minimo gli impatti negativi sull'operatività aziendale in seguito a eventi catastrofici o attacchi, garantendo altresì la continuità delle attività anche in condizioni di emergenza.

● La Business Impact Analysis (BIA) permette di identificare in anticipo le aree strategiche e di stimare l'effetto economico e operativo causato da possibili interruzioni. Inoltre misura la probabilità che tali minacce possano verificarsi l'impatto che esse potrebbero avere sul business. Ha l'approccio Quantitativo (fattori numerici) e l'approccio Qualitativo (fattori non numerici)

● IRP (Incident Response Plan): contempla le azioni operative per una tempestiva risposta a incidenti informatici, includendo strategie di contenimento, analisi dell'evento, ripristino dei servizi e comunicazioni interne ed esterne.

In risposta al quesito iniziale, si evidenzia che gli utenti investono circa 1.500 € al minuto sulla piattaforma di e-commerce; di conseguenza, una sospensione del servizio può comportare una perdita economica stimata di circa 15.000 €. Oltre ai danni finanziari immediati, è necessario considerare anche gli effetti indiretti, come la riduzione della fiducia dei clienti, la possibile perdita degli utenti abituali e il danno alla reputazione dell'organizzazione, specialmente se tali incidenti si verificano frequentemente.

Ulteriori valutazioni azioni preventive per questa problematica:

CDN

Una CDN (Content Delivery Network) è una rete globale di server distribuiti che replica i contenuti di un sito in molte località.
Le CDN moderne includono meccanismi avanzati di mitigazione DDoS, in particolare:

- distribuzione geografica del traffico (edge computing)
- filtraggio del traffico malevolo prima che raggiunga il server origin
- integrazione con firewall applicativi (WAF)
- capacità di rete enorme per assorbire attacchi su larga scala

Un esempio sono **Cloudflare** (uno dei provider più forti al mondo per difesa DDoS grazie alla sua rete altamente distribuita, include un WAF integrato, con regole aggiornat) e **Akamai** (storicamente la CDN con più server al mondo e una grande reputazione nel settore sicurezza).

4. Response

L'applicazione Web viene infettata da un malware. La vostra priorità è che il malware non si propaghi sulla vostre rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infettata. Modificate la figura in slide 2 con la soluzione proposta.

In caso di infezione malware all'interno di un'applicazione web, la priorità consiste nel prevenire la propagazione del codice malevolo nella rete aziendale, proteggendo l'integrità dei sistemi e dei dati. Pur non avendo come obiettivo immediato la rimozione dell'accesso dell'attaccante alla macchina compromessa, è essenziale attuare un contenimento tempestivo ed efficace della minaccia.

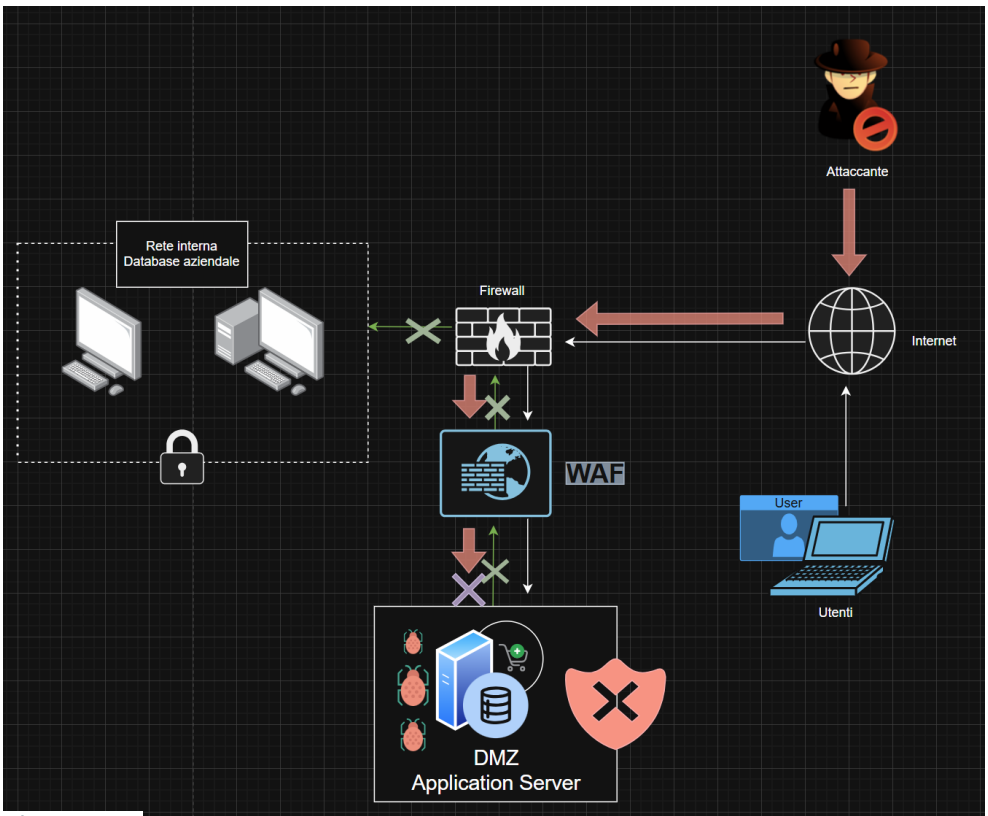

Figura 3

Come illustrato nella figura 3, è stata adottata una misura di contenimento consistente nella completa rimozione (contrassegnata

dalle ‘x’ verdi) della rete interna dal collegamento, al fine di prevenire ulteriori diffusioni del malware. A seguito di questa azione, la rete interna risulta completamente isolata dalla connessione a internet. Questa rappresenta la strategia di contenimento più rigorosa tra quelle disponibili, necessaria nei casi in cui si debbano tutelare asset critici. In questo scenario, dove è già in atto un attacco e la priorità è l’analisi forense e il contenimento passivo, l'IDS ci consente di:

Si osserva che tale approccio consente all’attaccante di mantenere l’accesso sulla DMZ, con potenziali ripercussioni sugli utenti dell’e-commerce. L’azienda, valutando l’impatto, può decidere di privilegiare la salvaguardia delle infrastrutture fondamentali rispetto alla reputazione, minimizzando le conseguenze economiche.

In presenza di dispositivi interni già compromessi da malware, sono stati implementati sistemi IDS per il monitoraggio e l'analisi accurata delle attività sospette nella rete isolata. Si sceglie di adottare IDS per evitare possibili interruzioni dei servizi essenziali o blocchi di traffico legittimo causati da falsi positivi, salvaguardando la continuità operativa durante la gestione dell’incidente.

- Individuare eventuali movimenti laterali del malware;
- Analizzare i pattern di attacco e i payload senza interferire con il traffico;
- Monitorare i tentativi di connessione verso altri host interni;
- Sviluppare una risposta mirata basata sulle evidenze raccolte.

In pratica, l'IDS viene posizionato tra segmenti della rete interna, operando come osservatore silente in grado di individuare segnali di compromissione senza alterare il normale funzionamento dell'infrastruttura. Di seguito si evidenziano le principali differenze tra IDS, IPS e Firewall:

Firewall: gestisce e limita il flusso del traffico di rete sulla base di regole predefinite.

IDS: identifica potenziali attacchi e notifica tramite allarmi, senza intervenire direttamente sul traffico.

IPS: rileva e blocca automaticamente le minacce; spesso è integrato con l’IDS in sistemi di protezione avanzati IDS/IPS.

Questa configurazione permette di raccogliere informazioni sull'attaccante prima di procedere con la rimozione. Il traffico viene registrato e inviato al SIEM (Security Information and Event Management) per un'analisi centralizzata, utile a migliorare le difese e aggiornare il piano IRP (Incident Response Plan).